

 AIF – Domain 5: Bảo Mật, Quản Trị & Tuân Thủ AI

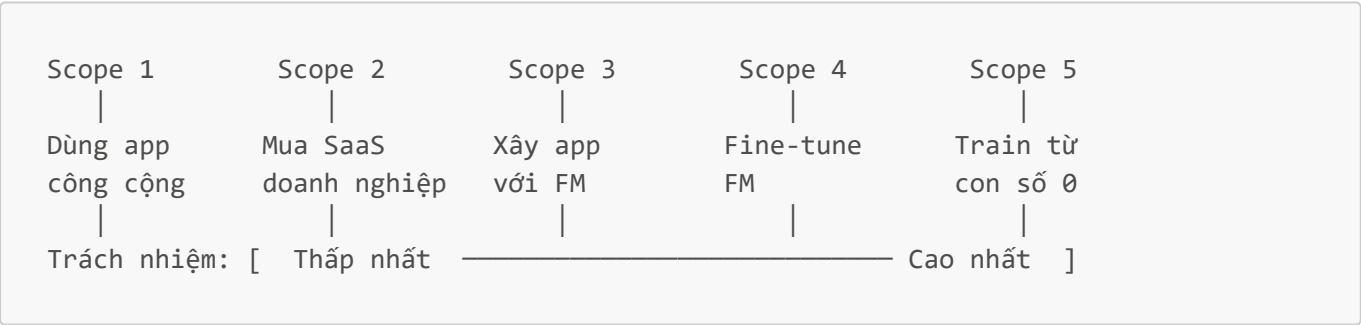
1. Amazon Bedrock Guardrails – Bộ Lọc Đa Tầng

(Xem thêm tổng quan Guardrails ở Domain 4 – phần này tập trung vào các cơ chế **chuyên sâu**)

Cơ chế	Chức năng chi tiết
Content Filters	Thiết lập ngưỡng (threshold) cho từng danh mục: hận thù · xúc phạm · tình dục · bạo lực
Sensitive Information Filters	Tự động mask (ẩn) PII (số điện thoại, email, địa chỉ...) trong cả đầu vào lẫn đầu ra
Word Filters	Tạo danh sách đen tùy chỉnh (Custom word list) cho thuật ngữ công ty hoặc tên đối thủ cạnh tranh
Contextual Grounding Check	Kiểm tra câu trả lời AI có thực sự dựa trên dữ liệu nguồn (RAG) không → chặn ảo giác ngay lập tức

2. GenAI Security Scoping Matrix – 5 Cấp Độ Trách Nhiệm

 **Quy tắc vàng:** Càng đi sâu tùy chỉnh mô hình (Scope 1 → 5), trách nhiệm bảo mật của **khách hàng càng lớn**.



Chi Tiết Từng Scope

● Scope 1 – Tiêu thụ ứng dụng GenAI công cộng

- **Hành động:** Nhân viên dùng ChatGPT, Claude web, Gemini miễn phí/trả phí công khai
- **Trách nhiệm của bạn (Rất thấp):** Chỉ quản lý **dữ liệu đầu vào (Prompt)**
-  **Rủi ro chính:** Nhân viên nhập mã nguồn mật / dữ liệu khách hàng vào tool công cộng → rò rỉ
- **Giải pháp:** Ban hành chính sách rõ ràng cấm nhập dữ liệu nhạy cảm + đào tạo nhận thức

● Scope 2 – Tiêu thụ ứng dụng GenAI doanh nghiệp

- **Hành động:** Mua SaaS GenAI (Amazon Q Business, Microsoft Copilot)
- **Trách nhiệm của bạn (Thấp):** AWS lo toàn bộ hạ tầng & mô hình
- **Bạn chịu trách nhiệm:**

- Quản lý **quyền truy cập (IAM/Identity)** – ai được dùng Q Business
- Cấu hình **phân quyền dữ liệu nội bộ** (tránh Q trả lời lộ lương sếp cho nhân viên)

● **Scope 3 – Xây dựng ứng dụng với FM có sẵn**

- **Hành động:** Gọi API đến Foundation Models qua Amazon Bedrock để xây chatbot riêng
- **Trách nhiệm của bạn (Trung bình):**

Trách nhiệm	Mô tả
App Security	Chống Prompt Injection vào ứng dụng
Encryption in transit	Mã hóa dữ liệu truyền đi (TLS/SSL)
Guardrails	Thiết lập bộ lọc an toàn cho ứng dụng

● **Scope 4 – Fine-tune Foundation Model**

- **Hành động:** Tải dữ liệu độc quyền (hồ sơ bệnh án, tài liệu pháp lý...) để Fine-tune qua Bedrock hoặc SageMaker
- **Trách nhiệm của bạn (Cao):** Tất cả Scope 3 + thêm:
 - **Bảo mật tập dữ liệu huấn luyện** – S3 bucket chứa dữ liệu Fine-tune phải cấu hình đúng
 - ⚠ Nếu vô tình để Public bucket → dữ liệu nhạy cảm bị lộ hoàn toàn
 - **Chất lượng & Bias** của mô hình sau tinh chỉnh

➖ **Scope 5 – Train mô hình từ con số 0**

- **Hành động:** Dùng EC2 GPU hoặc SageMaker tự viết thuật toán, train FM hoàn toàn mới
- **Trách nhiệm của bạn (Tối đa):** AWS chỉ cung cấp phần cứng – **mọi thứ còn lại bạn tự lo**

Trách nhiệm	Chi tiết
Network Security	VPC, Security Groups, Firewall
Model Weights	Bảo vệ trọng số mô hình – tài sản trí tuệ đắt giá nhất
Algorithm Code	Bảo mật mã nguồn thuật toán
OS & Container	Patching hệ điều hành, quản lý container

3. Bảo Mật Hạ Tầng & Kết Nối

VPC Endpoints – AWS PrivateLink

🔴 **Câu trả lời chuẩn** cho đề thi hỏi: "Làm sao đảm bảo dữ liệu không rò rỉ khi gọi API Bedrock/SageMaker?"

Không có VPC Endpoint	Có VPC Endpoint (PrivateLink)
VPC → Internet công cộng	VPC → AWS PrivateLink → Bedrock

→ Bedrock API

(Không qua Internet)

⚠️ Rủi ro rò rỉ

✅ Hoàn toàn riêng tư

Mã Hóa Dữ Liệu

Trạng thái	Phương pháp	Dịch vụ
In-transit (đang truyền)	TLS/SSL	Tự động
At-rest (đang lưu trữ)	AWS KMS (Key Management Service)	S3, Vector DB, SageMaker

Amazon Macie

Dùng ML để **tự động tìm kiếm và bảo vệ PII** được lưu trữ trên **S3**.

	Macie	Bedrock Guardrails
Phạm vi	Dữ liệu lưu trữ trên S3	PII trong prompt/response real-time
Mục đích	Phát hiện & cảnh báo PII	Mask/ẩn PII khi AI xử lý

4. Bộ Ba Giám Sát & Kiểm Toán

🔍 Keywords thi:

- "Audit / Logging / Ai đã làm gì" → **CloudTrail**
- "Performance / Latency / Alarm" → **CloudWatch**
- "Truy ngược nguồn gốc dữ liệu" → **Data Lineage (SageMaker)**

Dịch vụ	Chức năng	Ví dụ use case
AWS CloudTrail	Ghi lại mọi lệnh gọi API (ai, làm gì, lúc nào)	"Ai đã truy cập Model Claude 3 lúc 2 giờ sáng?" → Phục vụ Compliance
Amazon CloudWatch	Theo dõi hiệu suất (latency, lỗi, token consumed) + thiết lập Alarms	Cảnh báo khi chi phí token vượt ngưỡng
SageMaker Data Lineage	Vẽ bản đồ: S3 → Tiền xử lý → Training → Model Artifact	Truy ngược khi model đưa ra kết quả sai lệch

Công Cụ Tuân Thủ (Compliance)

Dịch vụ	Chức năng
AWS Artifact	Tải báo cáo tuân thủ chính thức (ISO, PCI DSS, SOC 1/2/3)
AWS Audit Manager	Tự động thu thập bằng chứng để phục vụ kiểm toán liên tục

5. AI Governance – Quản Trị Con Người & Quy Trình

🏛️ Đừng chỉ tập trung kỹ thuật – quản trị **con người và quy trình** cũng bị hỏi trong thi.

Yếu tố quản trị	Mô tả	Nguyên tắc cốt lõi
IAM	Kiểm soát quyền truy cập vào từng Model cụ thể	Least Privilege – chỉ cấp đúng quyền cần thiết
Governance Committee	Hội đồng phê duyệt use case AI về đạo đức & pháp lý	Giám sát con người (Human oversight)
Training & Awareness	Đào tạo nhân viên về rủi ro Scope 1	Nhân viên không nhập dữ liệu nhạy cảm vào tool công cộng

6. Bảng Tra Cứu Nhanh – Domain 5

Từ khóa trong đề	Dịch vụ / Giải pháp
Dữ liệu không đi qua Internet / Private connection	VPC Endpoint (PrivateLink)
Audit / Ai đã làm gì / Lịch sử API	AWS CloudTrail
Hiệu suất / Latency / Alarm / Token usage	Amazon CloudWatch
Filter / Mask PII trong prompt/response	Bedrock Guardrails (Sensitive Info Filter)
Tìm PII trong S3	Amazon Macie
Báo cáo ISO, PCI, SOC	AWS Artifact
Tự động thu thập bằng chứng kiểm toán	AWS Audit Manager
Truy ngược nguồn gốc dữ liệu training	SageMaker Data Lineage
AI trả lời có dựa trên tài liệu nguồn không	Bedrock Guardrails – Contextual Grounding Check
Mã hóa dữ liệu lưu trữ	AWS KMS
Nhân viên dùng ChatGPT công cộng → rủi ro	Scope 1 → chính sách + đào tạo
Fine-tune với dữ liệu nhạy cảm	Scope 4 → bảo mật S3 training bucket
Train từ đầu, tự quản lý GPU	Scope 5 → trách nhiệm cao nhất
Quyền hạn tối thiểu	IAM Least Privilege
Hội đồng phê duyệt use case AI	Governance Committee

 Tài liệu ôn tập AIF – Domain 5: Security, Governance & Compliance